Processo de Avaliação de Riscos e Tratamento de Riscos para Modelos de IA Generativa

Prof. Anderson Oliveira da Silva, phD

Gestor de Segurança da Informação

Encarregado de Dados Pessoais

anderson@inf.puc-rio.br

Pós-graduação em Compliance de Cibersegurança

Departamento de Informática

Coordenação Central de Educação Continuada

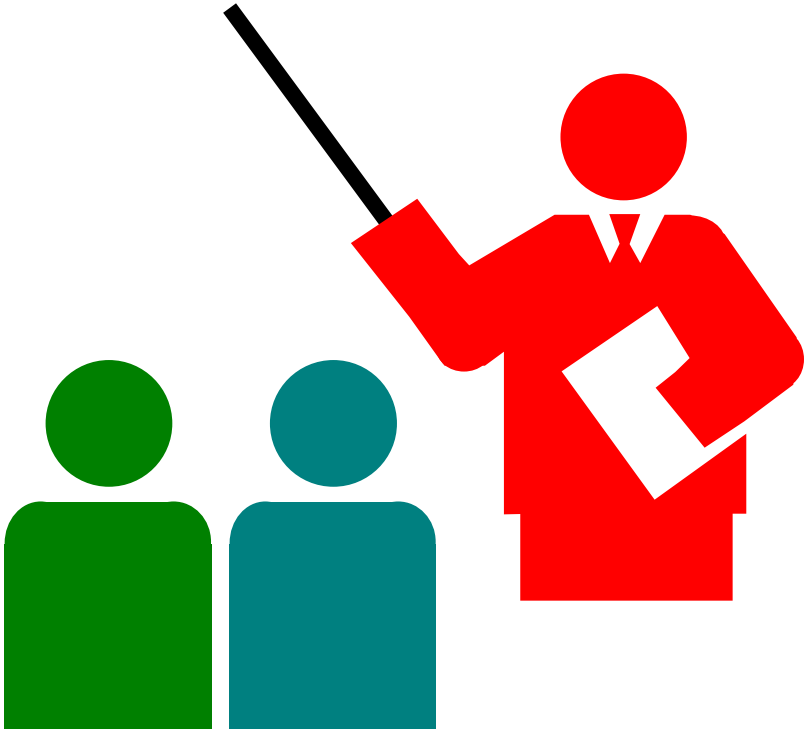
PUC-Rio

Ementa

Processo de Avaliação de Riscos e Tratamento de Riscos para Modelos de IA Generativa:

- **Ciclo de Vida de Modelos Generativos**
- **Etapas do Processo de Avaliação de Riscos**
- **Processo de Avaliação de Riscos Aplicado**
- **Tratamento de Riscos Aplicado**

Ciclo de Vida de Modelos Generativos



Ciclo de Vida de Modelos Generativos

Um ciclo de vida de modelos generativos é tipicamente formado por 10 etapas chaves:

1. **Caso de Uso e Escopo (Use Case & Scope):**
   - **Identificar o problema a ser resolvido e selecionar a classe de modelo adequada.**
2. **Coleta e Ingestão de Dados (Data Acquisition):**
   - **Obter grandes volumes de dados (texto, imagem, código, etc).**
3. **Preparação e Curadoria de Dados (Data Processing):**
   - **Limpeza, rotulagem, filtragem e transformação.**
4. **Treinamento do Modelo (Model Training):**
   - **Ajuste dos parâmetros do modelo (deep learning, transformers, diffusion, etc).**
5. **Avaliação e Validação (Evaluation & Testing):**
   - **Medir desempenho, robustez e segurança.**

Ciclo de Vida de Modelos Generativos

Um ciclo de vida de modelos generativos é tipicamente formado por 10 etapas chaves:

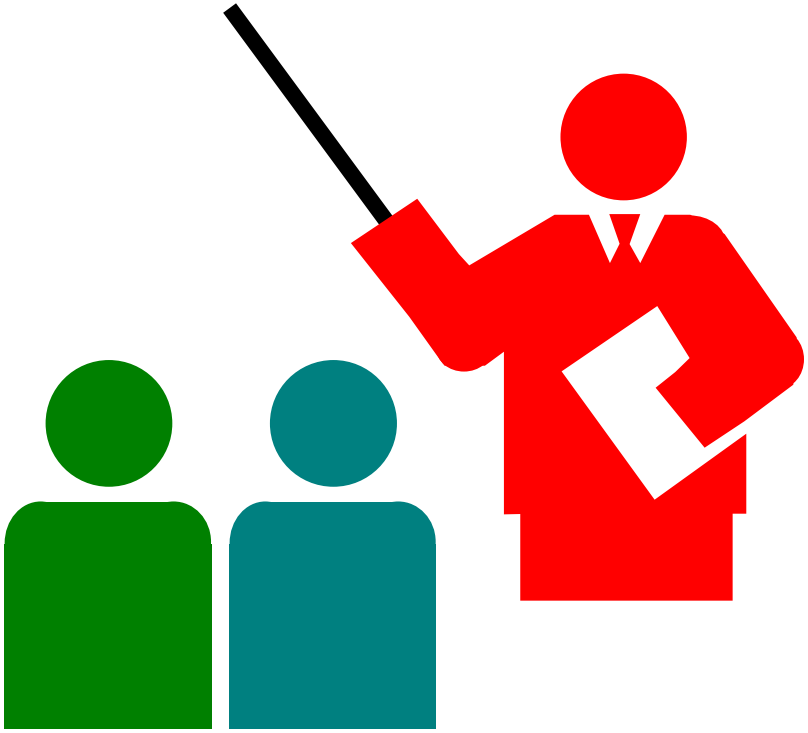
6. **Ajuste Fino e Alinhamento (Fine-tuning & Alignment)**
   - **Realizar aprendizado por reforço (feedback humano, instrução supervisionada).**
7. **Implantação (Deployment):**
   - **Disponibilizar o modelo para uso via API, app ou SaaS.**
8. **Operação e Monitoramento (Operation & Monitoring):**
   - **Acompanhar o comportamento em produção.**
9. **Manutenção e Retreinamento (Maintenance):**
   - **Melhorar continuamente o modelo.**
10. **Desativação (Decomissioning):**
    - **Encerrar uso do modelo.**

Ciclo de Vida de Modelos Generativos

Pontos críticos de risco no ciclo de vida de modelos generativos:

1. **Caso de Uso e Escopo (Use Case & Scope):**
   - **Risco: problema mal formulado, ambíguo ou desalinhado com o objetivo real, escolha errada do modelo, desperdício de recursos.**
2. **Coleta e Ingestão de Dados (Data Acquisition):**
   - **Risco: uso de dados pessoais sem base legal adequada, dados sensíveis, dados obtidos de forma ilícita.**
3. **Preparação e Curadoria de Dados (Data Processing):**
   - **Risco: ausência de minimização, inclusão de vieses, falta de controle de qualidade.**
4. **Treinamento do Modelo (Model Training):**
   - **Risco: memorização de dados pessoais, falta de documentação e rastreabilidade.**

Processo de Avaliação de Riscos



Processo de Avaliação de Riscos

O processo de avaliação de riscos é dividido em três etapas. (ISO27005, 2023, p.19)

- **Identificação de riscos:**
  - **Determinar o que pode causar uma perda potencial (vulnerabilidades e ameaças) e deixar claro como, onde e por que a perda pode acontecer.**
- **Análise de riscos:**
  - **Fazer uma avaliação da gravidade das consequências das ameaças e uma avaliação da probabilidade das ameaças se concretizarem, e determinar o nível de risco estimado a partir da combinação da probabilidade das ameaças com as suas consequências (impactos).**
- **Avaliação de riscos:**
  - **Fazer a comparação dos resultados da análise de riscos com critérios de risco para determinar se o risco é aceitável e priorizar os riscos analisados para o tratamento de riscos.**

Processo de Avaliação de Riscos – Identificação dos Riscos

2. Avaliação de riscos à privacidade e à proteção de dados

- **2.1 Uso excessivo ou indevido de dados;**
- **2.2 Falhas de transparência;**
- **2.3 Perfilamento e inferência comportamental;**
- **2.4 Falsos positivos e discriminação algorítmica;**
- **2.5 Vazamento de dados através de saídas (outputs) do modelo;**
- **2.6 Reputacionais, regulatórios e éticos.**

Processo de Avaliação de Riscos – Identificação dos Riscos

Conceitos básicos: Agente de Ameaça

- **Fonte que pode causar um incidente de segurança da informação por meio da exploração de uma vulnerabilidade.**

Tipo de Agente	Descrição	Exemplos
Interno (insider)	Atua dentro da organização com acesso legítimo.	Funcionário desonesto, técnico negligente, prestador de serviço terceirizado.
Externo (outsider)	Atua fora do perímetro da organização.	Hacker, grupo de cibercriminisos, concorrente.
Parceiro/Fornecedor	Atua por meio de relações de negócio.	Empresa terceirizada com acesso à rede corporativa.
Ambiental/Natural	Ameaça física ou ambiental.	Tempestades, incêndios, inundações, falha de energia.
Tecnológico/Acidental	Ação não intencional de sistemas ou pessoas.	Erro humano, falha de software, mau funcionamento de equipamento.

Processo de Avaliação de Riscos – Identificação de Riscos

2. Avaliação de riscos à privacidade e à proteção de dados pessoais: Modelos Generativos

- **Risco:**
  - **2.1 Uso excessivo ou indevido de dados pessoais.**
- **Ameaças:**
  - **O risco de uso excessivo ou indevido de dados ocorre quando modelos generativos:**
    - **Tratam mais dados do que o necessário para a finalidade declarada;**
    - **Utilizam dados para finalidades secundárias não informadas ou não compatíveis;**
    - **Reaproveitam dados de treinamento para novos contextos sem reavaliação de riscos.**

Processo de Avaliação de Riscos – Análise de Riscos

Critério para análise de riscos: Probabilidade.

Probabilidade	Descrição
BAIXA	O **evento é improvável**; não há histórico ou depende da combinação de diversos fatores pouco prováveis.
MÉDIA	O **evento pode ocorrer algumas vezes ao longo do ano**, especialmente diante de falhas pontuais ou vulnerabilidades conhecidas.
ALTA	O **evento é provável/frequente**, havendo histórico de ocorrências ou exposição significativa a ameaças.

Processo de Avaliação de Riscos – Análise de Riscos

Critério para análise de riscos: Consequência.

Consequência	Descrição
Baixa	**Impacto limitado**, **reversível**, com **danos mínimos** ou **inexistentes** aos titulares (ex.: pequeno atraso no acesso).
Média	**Impacto relevante**, mas **não catastrófico**, com possibilidade de constrangimentos, perdas financeiras moderadas ou transtornos significativos.
Alta	**Impacto grave**, com **alto potencial de danos materiais** e/ou **morais** aos titulares, incluindo discriminação, fraude ou exposição em larga escala.

Processo de Avaliação de Riscos – Análise de Riscos

Critério para análise de riscos: Matriz de Risco (Mapa de Calor).

Matriz de Risco			
	Probabilidade		
Consequência	Baixa	Média	Alta
Baixa	Baixo	Baixo	Médio
Média	Baixo	Médio	Alto
Alta	Médio	Alto	Crítico

Processo de Avaliação de Riscos – Avaliação de Riscos

Critério para níveis de risco e tratamento recomendado:

Risco	Descrição	Tratamento
Baixo	Risco residual com impacto e probabilidade reduzidos; não exige ação adicional imediata.	Aceitar o risco, mantendo monitoramento de rotina
Médio	Risco relevante, mas gerenciável com controles adequados.	Modificar o risco com medidas de mitigação adicionais e/ou aceitar com justificativa formal.
Alto	Risco significativo aos direitos dos titulares, exigindo ação prioritária.	Modificar o risco (implementar controles robustos). Caso não seja possível reduzir, avaliar evitar o tratamento ou escalar para decisão da alta direção.
Crítico	Risco intolerável, com alto potencial de danos graves aos titulares.	Evitar o risco (interromper o tratamento) até implementação de medidas suficientes. Em situações residuais, pode-se considerar compartilhar o risco (ex.: seguro) aliado a forte mitigação, com aprovação da alta administração.

Processo de Avaliação de Riscos – Análise de Riscos

Ativo: Modelos Generativos

Modelos Generativos				
2.1 Uso excessivo ou indevido de dados pessoais		**Pi**	**Ci**	**Ri**
A.2.1.1	**Tratam mais dados do que o necessário para a finalidade declarada** Probabilidade: prática comum em pipelines de IA (coleta massiva / scraping / datasets amplos). Consequência:	Alta		

Probabilidade	Descrição
BAIXA	O **evento é improvável**; não há histórico ou depende da combinação de diversos fatores pouco prováveis.
MÉDIA	O **evento pode ocorrer algumas vezes ao longo do ano**, especialmente diante de falhas pontuais ou vulnerabilidades conhecidas.
ALTA	O **evento é provável/frequente**, havendo histórico de ocorrências ou exposição significativa a ameaças.

Processo de Avaliação de Riscos – Análise de Riscos

Ativo: Modelos Generativos

Modelos Generativos				
2.1 Uso excessivo ou indevido de dados pessoais		**Pi**	**Ci**	**Ri**
A.2.1.1	**Tratam mais dados do que o necessário para a finalidade declarada** Probabilidade: prática comum em pipelines de IA (coleta massiva / scraping / datasets amplos). Consequência: violação direta dos princípios da necessidade e minimização (art. 6º LGPD).	Alta	Alta	

Consequência	Descrição
Baixa	**Impacto limitado**, **reversível**, com **danos mínimos** ou **inexistentes** aos titulares (ex.: pequeno atraso no acesso).
Média	**Impacto relevante**, mas **não catastrófico**, com possibilidade de constrangimentos, perdas financeiras moderadas ou transtornos significativos.
Alta	**Impacto grave**, com **alto potencial de danos materiais** e/ou **morais** aos titulares, incluindo discriminação, fraude ou exposição em larga escala.

Processo de Avaliação de Riscos – Análise de Riscos

Ativo: Modelos Generativos

Modelos Generativos				
2.1 Uso excessivo ou indevido de dados pessoais		**Pi**	**Ci**	**Ri**
A.2.1.1	**Tratam mais dados do que o necessário para a finalidade declarada** Probabilidade: prática comum em pipelines de IA (coleta massiva / scraping / datasets amplos). Consequência: violação direta dos princípios da necessidade e minimização (art. 6º LGPD).	Alta	Alta	**Crítico**

Matriz de Risco			
	Probabilidade		
Consequência	**Baixa**	**Média**	**Alta**
Baixa	**Baixo**	**Baixo**	**Médio**
Média	**Baixo**	**Médio**	**Alto**
Alta	**Médio**	**Alto**	**Crítico**

Processo de Avaliação de Riscos – Análise de Riscos

Ativo: Modelos Generativos

Modelos Generativos				
2.1 Uso excessivo ou indevido de dados pessoais		**Pi**	**Ci**	**Ri**
A.2.1.1	**Tratam mais dados do que o necessário para a finalidade declarada** Probabilidade: prática comum em pipelines de IA (coleta massiva / scraping / datasets amplos). Consequência: violação direta dos princípios da necessidade e minimização (art. 6º LGPD).	Alta	Alta	**Crítico**

Tratamento dos riscos		Ameaça	Tipo	Pr	Cr	Rr
T.2.1.1		A.2.1.1	Modificar			

Processo de Avaliação de Riscos – Análise de Riscos

Ativo: Modelos Generativos

Modelos Generativos				
2.1 Uso excessivo ou indevido de dados pessoais		**Pi**	**Ci**	**Ri**
A.2.1.1	**Tratam mais dados do que o necessário para a finalidade declarada** Probabilidade: prática comum em pipelines de IA (coleta massiva / scraping / datasets amplos). Consequência: violação direta dos princípios da necessidade e minimização (art. 6º LGPD).	Alta	Alta	**Crítico**

Tratamento dos riscos		Ameaça	Tipo	Pr	Cr	Rr
T.2.1.1	Controles de minimização, governança de dados, definição formal de finalidade, auditoria de datasets.	A.2.1.1	Modificar			

Processo de Avaliação de Riscos – Tratamento de Riscos

Ativo: Modelos Generativos

Tratamento dos riscos		Ameaça	Tipo	Pr	Cr	Rr
T.2.1.1	Controles de minimização, governança de dados, definição formal de finalidade, auditoria de datasets.	A.2.1.1	Modificar			

Para calcularmos a redução da probabilidade e da consequência, um método prático é verificar o tipo do controle...

- ***Preventivo***: atua antes que um incidente ocorra, para evita-lo (ex: governança de dados, anonimização de dados, minimização de dados).
- ***Detectivo***: atua durante um incidente para identifica-lo (ex: auditoria de datasets, teste de reidentificação, avaliação de outputs).
- ***Corretivo***: atua após um incidente para minimizar seus impactos e restaurar a normalidade (ex: eliminação de dados, re-treinamento com dataset limpo).

Processo de Avaliação de Riscos – Tratamento de Riscos

Ativo: Modelos Generativos

Tratamento dos riscos		Ameaça	Tipo	Pr	Cr	Rr
T.2.1.1	Controles de minimização, governança de dados, definição formal de finalidade, auditoria de datasets.	A.2.1.1	Modificar	Baixa	Média	

Tipo do Controle	Redução na Probabilidade	Redução na Consequência
Preventivo (ex: governança de dados, anonimização)	X	-
Corretivo (ex: eliminação de dados, re-treinamento com dataset limpo)	-	X
Detectivo (ex: auditoria de datasets, teste de reidentificação, monitoramento)	X	X

Processo de Avaliação de Riscos – Tratamento de Riscos

Ativo: Modelos Generativos

Tratamento dos riscos		Ameaça	Tipo	Pr	Cr	Rr
T.2.1.1	Controles de minimização, governança de dados, definição formal de finalidade, auditoria de datasets.	A.2.1.1	Modificar	Baixa	Média	**Baixo**

Tipo do Controle	Redução na Probabilidade	Redução na Consequência
Preventivo (ex: governança de dados, anonimização)	X	-
Corretivo (ex: eliminação de dados, re-treinamento com dataset limpo)	-	X
Detectivo (ex: auditoria de datasets, teste de reidentificação, monitoramento)	X	X

Processo de Avaliação de Riscos – Análise de Riscos

Ativo: Modelos Generativos

Modelos Generativos				
2.1 Uso excessivo ou indevido de dados pessoais		Pi	Ci	Ri
A.2.1.2	**Utilizam dados para finalidades secundárias não informadas ou não compatíveis** Probabilidade: prática frequente em IA (reuso de datasets, fine-tuning secundário). Consequência:	Alta		

Probabilidade	Descrição
BAIXA	O **evento é improvável**; não há histórico ou depende da combinação de diversos fatores pouco prováveis.
MÉDIA	O **evento pode ocorrer algumas vezes ao longo do ano**, especialmente diante de falhas pontuais ou vulnerabilidades conhecidas.
ALTA	O **evento é provável/frequente**, havendo histórico de ocorrências ou exposição significativa a ameaças.

Processo de Avaliação de Riscos – Análise de Riscos

Ativo: Modelos Generativos

Modelos Generativos				
2.1 Uso excessivo ou indevido de dados pessoais		**Pi**	**Ci**	**Ri**
A.2.1.2	**Utilizam dados para finalidades secundárias não informadas ou não compatíveis** Probabilidade: prática frequente em IA (reuso de datasets, fine-tuning secundário). Consequência: violação do princípio da finalidade e adequação (art. 6º LGPD) com risco jurídico elevado (sanções e bloqueio de tratamento).	Alta	Alta	

Consequência	Descrição
Baixa	**Impacto limitado**, **reversível**, com **danos mínimos** ou **inexistentes** aos titulares (ex.: pequeno atraso no acesso).
Média	**Impacto relevante**, mas **não catastrófico**, com possibilidade de constrangimentos, perdas financeiras moderadas ou transtornos significativos.
Alta	**Impacto grave**, com **alto potencial de danos materiais** e/ou **morais** aos titulares, incluindo discriminação, fraude ou exposição em larga escala.

Processo de Avaliação de Riscos – Análise de Riscos

Ativo: Modelos Generativos

Modelos Generativos				
2.1 Uso excessivo ou indevido de dados pessoais		**Pi**	**Ci**	**Ri**
A.2.1.2	**Utilizam dados para finalidades secundárias não informadas ou não compatíveis** Probabilidade: prática frequente em IA (reuso de datasets, fine-tuning secundário). Consequência: violação do princípio da finalidade e adequação (art. 6º LGPD) com risco jurídico elevado (sanções e bloqueio de tratamento).	Alta	Alta	**Crítico**

Matriz de Risco			
	Probabilidade		
Consequência	**Baixa**	**Média**	**Alta**
Baixa	**Baixo**	**Baixo**	**Médio**
Média	**Baixo**	**Médio**	**Alto**
Alta	**Médio**	**Alto**	**Crítico**

Processo de Avaliação de Riscos – Análise de Riscos

Ativo: Modelos Generativos

Modelos Generativos				
2.1 Uso excessivo ou indevido de dados pessoais		**Pi**	**Ci**	**Ri**
A.2.1.2	**Utilizam dados para finalidades secundárias não informadas ou não compatíveis** Probabilidade: prática frequente em IA (reuso de datasets, fine-tuning secundário). Consequência: violação do princípio da finalidade e adequação (art. 6º LGPD) com risco jurídico elevado (sanções e bloqueio de tratamento).	Alta	Alta	**Crítico**

Tratamento dos riscos		Ameaça	Tipo	Pr	Cr	Rr
T.2.1.2		A.2.1.2	Modificar			

Processo de Avaliação de Riscos – Análise de Riscos

Ativo: Modelos Generativos

Modelos Generativos				
2.1 Uso excessivo ou indevido de dados pessoais		**Pi**	**Ci**	**Ri**
A.2.1.2	**Utilizam dados para finalidades secundárias não informadas ou não compatíveis** Probabilidade: prática frequente em IA (reuso de datasets, fine-tuning secundário). Consequência: violação do princípio da finalidade e adequação (art. 6º LGPD) com risco jurídico elevado (sanções e bloqueio de tratamento).	Alta	Alta	**Crítico**

Tratamento dos riscos		Ameaça	Tipo	Pr	Cr	Rr
T.2.1.2	definição clara de finalidade, gestão de consentimento, governança de dados, auditoria de uso de dados, monitoramento de pipelines de ML.	A.2.1.2	Modificar			

Processo de Avaliação de Riscos – Tratamento de Riscos

Ativo: Modelos Generativos

Tratamento dos riscos		Ameaça	Tipo	Pr	Cr	Rr
T.2.1.2	definição clara de finalidade, gestão de consentimento, governança de dados, auditoria de uso de dados, monitoramento de pipelines de ML.	A.2.1.2	Modificar	Baixa	Baixa	**Baixo**

Tipo do Controle	Redução na Probabilidade	Redução na Consequência
Preventivo (ex: governança de dados, anonimização)	X	-
Corretivo (ex: eliminação de dados, re-treinamento com dataset limpo)	-	X
Detectivo (ex: auditoria de datasets, teste de reidentificação, monitoramento)	X	X

Processo de Avaliação de Riscos – Análise de Riscos

Ativo: Modelos Generativos

Modelos Generativos				
2.1 Uso excessivo ou indevido de dados pessoais		**Pi**	**Ci**	**Ri**
A.2.1.3	**Reaproveitam dados de treinamento para novos contextos sem reavaliação de riscos.** Probabilidade: menos frequente que A2.1.1/A2.1.2, mas comum em ambientes maduros de IA. Consequência:	Média		

Probabilidade	Descrição
BAIXA	O **evento é improvável**; não há histórico ou depende da combinação de diversos fatores pouco prováveis.
MÉDIA	O **evento pode ocorrer algumas vezes ao longo do ano**, especialmente diante de falhas pontuais ou vulnerabilidades conhecidas.
ALTA	O **evento é provável/frequente**, havendo histórico de ocorrências ou exposição significativa a ameaças.

Processo de Avaliação de Riscos – Análise de Riscos

Ativo: Modelos Generativos

Modelos Generativos				
2.1 Uso excessivo ou indevido de dados pessoais		**Pi**	**Ci**	**Ri**
A.2.1.3	**Reaproveitam dados de treinamento para novos contextos sem reavaliação de riscos.** Probabilidade: menos frequente que A2.1.1/A2.1.2, mas comum em ambientes maduros de IA. Consequência: violação indireta da finalidade e adequação, com risco de mudança de contexto que aumenta de impacto ao titular.	Média	Alta	

Consequência	Descrição
Baixa	**Impacto limitado**, **reversível**, com **danos mínimos** ou **inexistentes** aos titulares (ex.: pequeno atraso no acesso).
Média	**Impacto relevante**, mas **não catastrófico**, com possibilidade de constrangimentos, perdas financeiras moderadas ou transtornos significativos.
Alta	**Impacto grave**, com **alto potencial de danos materiais** e/ou **morais** aos titulares, incluindo discriminação, fraude ou exposição em larga escala.

Processo de Avaliação de Riscos – Análise de Riscos

Ativo: Modelos Generativos

Modelos Generativos				
2.1 Uso excessivo ou indevido de dados pessoais		**Pi**	**Ci**	**Ri**
A.2.1.3	**Reaproveitam dados de treinamento para novos contextos sem reavaliação de riscos.** Probabilidade: menos frequente que A2.1.1/A2.1.2, mas comum em ambientes maduros de IA. Consequência: violação indireta da finalidade e adequação, com risco de mudança de contexto que aumenta de impacto ao titular.	Média	Alta	**Alto**

Matriz de Risco			
	Probabilidade		
Consequência	**Baixa**	**Média**	**Alta**
Baixa	**Baixo**	**Baixo**	**Médio**
Média	**Baixo**	**Médio**	**Alto**
Alta	**Médio**	**Alto**	**Crítico**

Processo de Avaliação de Riscos – Análise de Riscos

Ativo: Modelos Generativos

Modelos Generativos				
2.1 Uso excessivo ou indevido de dados pessoais		**Pi**	**Ci**	**Ri**
A.2.1.3	**Reaproveitam dados de treinamento para novos contextos sem reavaliação de riscos.** Probabilidade: menos frequente que A2.1.1/A2.1.2, mas comum em ambientes maduros de IA. Consequência: violação indireta da finalidade e adequação, com risco de mudança de contexto que aumenta de impacto ao titular.	Média	Alta	**Alto**

Tratamento dos riscos		Ameaça	Tipo	Pr	Cr	Rr
T.2.1.3		A.2.1.3	Modificar			

Processo de Avaliação de Riscos – Análise de Riscos

Ativo: Modelos Generativos

Modelos Generativos				
2.1 Uso excessivo ou indevido de dados pessoais		**Pi**	**Ci**	**Ri**
A.2.1.3	**Reaproveitam dados de treinamento para novos contextos sem reavaliação de riscos.** Probabilidade: menos frequente que A2.1.1/A2.1.2, mas comum em ambientes maduros de IA. Consequência: violação indireta da finalidade e adequação, com risco de mudança de contexto que aumenta de impacto ao titular.	Média	Alta	**Alto**

Tratamento dos riscos		Ameaça	Tipo	Pr	Cr	Rr
T.2.1.3	Reavaliação de risco (RIPD) a cada novo uso, política de reutilização de dados, auditoria de versionamento de datasets	A.2.1.3	Modificar			

Processo de Avaliação de Riscos – Tratamento de Riscos

Ativo: Modelos Generativos

Tratamento dos riscos		Ameaça	Tipo	Pr	Cr	Rr
T.2.1.3	Reavaliação de risco (RIPD) a cada novo uso, política de reutilização de dados, auditoria de versionamento de datasets	A.2.1.3	Modificar	Baixa	Média	**Baixo**

Tipo do Controle	Redução na Probabilidade	Redução na Consequência
Preventivo (ex: governança de dados, anonimização)	X	-
Corretivo (ex: eliminação de dados, re-treinamento com dataset limpo)	-	X
Detectivo (ex: auditoria de datasets, teste de reidentificação, monitoramento)	X	X

Processo de Avaliação de Riscos – Tratamento de Riscos

Controles Preventivos: evitar a materialização do risco

- **Governança e Compliance:**
  - **Definição formal de finalidade (limitação do propósito)**
  - **Registro de bases legais (art. 7º e 11 da LGPD)**
  - **Realização de DPIA/PIA para casos de alto risco**
  - **Política de governança de IA (papéis, responsabilidades)**
  - **Classificação de dados (pessoais, sensíveis, anonimizados)**
- **Dados:**
  - **Data minimization by design**
  - **Data inventory e data mapping**
  - **Anonimização e pseudonimização**
  - **Validação de origem dos dados**
  - **Curadoria de datasets confiáveis**
  - **Controle de reuso de dados (purpose binding)**

Processo de Avaliação de Riscos – Tratamento de Riscos

Controles Preventivos: evitar a materialização do risco

- **Arquitetura e Engenharia:**
  - **Privacy by design e security by design**
  - **Escolha adequada de arquitetura (LLM vs ML tradicional)**
  - **Isolamento de contexto (sandboxing de prompts e plugins)**
  - **Controle de acesso (IAM, Zero Trust)**
  - **Criptografia de dados (em repouso e em trânsito)**
- **Treinamento e Modelo:**
  - **Uso de differential privacy**
  - **Regularização para evitar overfitting/memorização**
  - **Validação de datasets contra poisoning**
  - **Treinamento com dados sintéticos (quando aplicável)**

Processo de Avaliação de Riscos – Tratamento de Riscos

Controles Preventivos: evitar a materialização do risco

- **Segurança de IA:**
  - **Proteção contra prompt injection (input validation)**
  - **Hardening de APIs e endpoints**
  - **Controle de supply chain (modelos, bibliotecas, pesos)**
  - **Red teaming (teste de segurança ofensiva) antes do deployment**
- **Operação e Uso:**
  - **Definição de políticas de uso aceitável**
  - **Implementação de guardrails (filtros de conteúdo)**
  - **Limitação de taxa (rate limiting)**
  - **Segregação de ambientes (dev/test/prod)**

Processo de Avaliação de Riscos – Tratamento de Riscos

Controles Detectivos: identificar eventos de risco ou incidentes em tempo hábil

- **Monitoramento de uso:**
  - **Logging estruturado de prompts e respostas**
  - **Monitoramento de comportamento anômalo**
  - **Detecção de uso indevido (fraude, phishing, abuso)**
  - **Monitoramento de drift do modelo**
- **Auditoria:**
  - **Auditoria de datasets (origem, conteúdo, finalidade)**
  - **Auditoria de pipelines de ML (MLOps)**
  - **Auditoria de conformidade (LGPD, políticas internas)**
  - **Revisão periódica de base legal**

Processo de Avaliação de Riscos – Tratamento de Riscos

Controles Detectivos: identificar eventos de risco ou incidentes em tempo hábil

- **Segurança:**
  - **Detecção de prompt injection**
  - **Detecção de exfiltração de dados**
  - **Monitoramento de acessos (IAM)**
  - **SIEM/SOC com correlação de eventos**
- **Qualidade e Ética:**
  - **Monitoramento de bias/fairness**
  - **Avaliação contínua de outputs (toxicidade, alucinação)**
  - **Feedback humano (human-in-the-loop)**
  - **Testes adversariais contínuos**

Processo de Avaliação de Riscos – Tratamento de Riscos

Controles Detectivos: identificar eventos de risco ou incidentes em tempo hábil

- **Rastreabilidade:**
  - **Data lineage (origem e uso dos dados)**
  - **Versionamento de datasets e modelos**
  - **Trilhas de auditoria (audit trails)**

Processo de Avaliação de Riscos – Tratamento de Riscos

Controles Corretivos/Contingência: responder a incidentes e reduzir impacto

- **Resposta a Incidentes:**
  - **Plano de resposta a incidentes de IA**
  - **Bloqueio imediato de usuários/inputs maliciosos**
  - **Revogação de acessos comprometidos**
  - **Rollback de modelo/versão**
- **Dados:**
  - **Eliminação de dados indevidos**
  - **Anonimização emergencial**
  - **Correção ou exclusão de datasets contaminados**
  - **Notificação de incidente (art. 48 LGPD)**

Processo de Avaliação de Riscos – Tratamento de Riscos

Controles Corretivos/Contingência: responder a incidentes e reduzir impacto

- **Modelo:**
  - **Re-treinamento com dataset corrigido**
  - **Fine-tuning corretivo**
  - **Desativação de funcionalidades de risco**
  - **Atualização de guardrails**
- **Jurídico/Compliance:**
  - **Comunicação a titulares (quando aplicável)**
  - **Revisão de base legal**
  - **Ajuste de políticas e contratos (controlador/operador)**
  - **Registro do incidente e lições aprendidas**

Processo de Avaliação de Riscos – Tratamento de Riscos

Controles Corretivos/Contingência: responder a incidentes e reduzir impacto

- **Continuidade:**
  - **Ativação de plano de continuidade (BCP)**
  - **Operação degradada (fallback para sistema determinístico)**
  - **Substituição temporária do modelo**

Obrigado!

Prof. Anderson Oliveira da Silva, phD

Gestor de Segurança da Informação

Encarregado de Dados Pessoais

anderson@inf.puc-rio.br

Pós-graduação em Compliance de Cibersegurança

Departamento de Informática

Coordenação Central de Educação Continuada

PUC-Rio